bakery-example.com

Passive security audit by Loïc Tellier · 2026-11-02 · overall grade = weakest area

High exposure: priority fixes are needed.

Overall	Website	Certificate & TLS	Email	Domain & DNS
F	**F**	**B**	**C**	**C-**
weakest area	15/100 · Mozilla HTTP Observatory scoring	70/100 · this project's scale (RFC 8996, 9325, certificate validity)	55/100 · this project's scale (RFC 7208, 7489, 6376, 8461)	45/100 · this project's scale (RFC 4033, 8659, 9083, 9162)

2 critical · 14 to improve · 11 compliant · 12 info

Summary for decision makers

Main risks

- A forgotten subdomain can be taken over to publish content in the company's name. (High impact)
- Outdated software on the site has known flaws that attackers exploit automatically. (High impact)
- Visitors' data (forms, logins) can be intercepted, for instance on public Wi-Fi. (High impact)

Effort 9 quick fix(es) (under 30 min each), 6 of a few hours, 1 project(s) needing a developer or a provider.
Applying the quick fixes alone would raise the overall grade from F to C.

Priority actions

1. **Forgotten subdomains (CT logs)** (Critical · High impact · Quick fix (under 30 min))
   Delete these DNS records now, or recreate the resource at the provider before someone else does.
2. **Accepted TLS versions** (To improve · High impact · Quick fix (under 30 min))
   Disable TLS 1.0 and 1.1 and only allow TLS 1.2 and 1.3 (current browsers no longer use the old versions).
3. **HTTP to HTTPS redirect** (To improve · High impact · Quick fix (under 30 min))
   Set up a permanent (301) redirect from HTTP to HTTPS.
4. **HSTS** (To improve · High impact · Quick fix (under 30 min))
   Add "Strict-Transport-Security: max-age=31536000; includeSubDomains".
5. **Clickjacking protection** (To improve · High impact · Quick fix (under 30 min))
   Add "X-Frame-Options: SAMEORIGIN" or "frame-ancestors 'self'" in the CSP.
6. **Software: PHP** (Critical · High impact · A few hours)
   Upgrade PHP to a supported version (test on a copy of the site first), and hide the version number.
7. **SPF (authorized senders)** (To improve · High impact · A few hours)
   Move to "~all", then "-all" once your senders are listed.
8. **DMARC (anti-spoofing policy)** (To improve · High impact · A few hours)
   After a few weeks of report analysis, move to "quarantine", then "reject".
9. **Content-Security-Policy** (To improve · High impact · Project (developer or provider))
   Define a CSP suited to the site, starting in "Report-Only" mode.
10. **HTTPS certificate** (To improve · Medium impact · Quick fix (under 30 min))
    Check that automatic renewal is in place.
11. **DNSSEC** (To improve · Medium impact · A few hours)
    Enable DNSSEC at your DNS host, then publish the DS record at your registrar (often a single option in their interface).
12. **CAA (allowed certificate authorities)** (To improve · Low impact · Quick fix (under 30 min))
    Publish a CAA record naming the authority you use, e.g. 0 issue "letsencrypt.org".

13. **Transfer lock** (To improve · Low impact · Quick fix (under 30 min))
    Turn on the transfer lock (often called "registrar lock") at your registrar.
14. **Software version disclosure** (To improve · Low impact · Quick fix (under 30 min))
    Hide version numbers in the server configuration.
15. **MTA-STS (encrypted email delivery)** (To improve · Low impact · A few hours)
    Publish an MTA-STS policy (in "testing" mode first), or enable it in your email service.
16. **Trackers before consent** (To improve · Low impact · A few hours)
    Load these services only after the visitor agrees, through the consent banner (or a tag manager in consent mode); audience measurement may be exempt under the CNIL's conditions.

Website security

Critical — **Software: PHP** — not scored

PHP 7.4.3 no longer gets security fixes since 2022-11-28: every flaw found since then stays open, and attackers scan for these versions automatically.

> Upgrade PHP to a supported version (test on a copy of the site first), and hide the version number.

Source: endoflife.date (end of support dates of software versions) — See also: CNIL personal data security guide (2024): securing websites

---

To improve — **Content-Security-Policy** — -25 pts

Missing: no limit on which scripts the page can load (protection against XSS injection).

> Define a CSP suited to the site, starting in "Report-Only" mode.

On Apache:

```
Header always set Content-Security-Policy-Report-Only "default-src 'self'; object-src 'none'; frame-ancestors 'self'"
```

Source: W3C Content Security Policy Level 3 — See also: ANSSI website guide PA-009 v2.0 (2021), R14, R15, R16

To improve — **HTTP to HTTPS redirect** — -20 pts

The site is still reachable over unencrypted HTTP, without a redirect.

> Set up a permanent (301) redirect from HTTP to HTTPS.

On Apache (.htaccess):

```
RewriteEngine On
RewriteCond %{HTTPS} off
RewriteRule ^ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]
```

Source: MDN TLS guide: HTTP redirection — See also: ANSSI website guide PA-009 v2.0 (2021), R1 · CNIL personal data security guide (2024): securing websites

---

To improve — **HSTS** — -20 pts

Missing: the browser is not required to use HTTPS on later visits.

> Add "Strict-Transport-Security: max-age=31536000; includeSubDomains".

On Apache:

```
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
```

Source: RFC 6797 (HTTP Strict Transport Security) — See also: ANSSI website guide PA-009 v2.0 (2021), R2

To improve — **Clickjacking protection** — -20 pts

The site can be displayed inside a frame on another site (clickjacking risk).

> Add "X-Frame-Options: SAMEORIGIN" or "frame-ancestors 'self'" in the CSP.

On Apache:

```
Header always set X-Frame-Options "SAMEORIGIN"
```

Source: RFC 7034 (X-Frame-Options) — See also: ANSSI website guide PA-009 v2.0 (2021), R17, R18

To improve — **Software version disclosure** — not scored

The server announces its versions (Server: Apache/2.4.41 (Ubuntu); X-Powered-By: PHP/7.4.3), which helps an attacker target known vulnerabilities.

> Hide version numbers in the server configuration.

On Apache (main configuration; for PHP, expose_php = Off in php.ini):

```
ServerTokens Prod
ServerSignature Off
```

Source: OWASP Secure Headers Project

To improve	**Trackers before consent** The page loads these services directly, without holding them back for consent: Meta (Facebook) Pixel (www.facebook.com); Google Analytics (www.googletagmanager.com). No known consent banner found. > Load these services only after the visitor agrees, through the consent banner (or a tag manager in consent mode); audience measurement may be exempt under the CNIL's conditions. Source: CNIL: rules for cookies and other trackers (ePrivacy directive, article 5(3))	not scored
Info	**Cookies** No cookies set on the home page. Source: RFC 6265 (HTTP cookies) and MDN cookie guide — See also: ANSSI website guide PA-009 v2.0 (2021), §5.5.3 · CNIL personal data security guide (2024): securing websites	0 pts
Info	**Referrer-Policy** Missing: browsers apply their default policy (strict-origin-when-cross-origin in recent versions). > Add "Referrer-Policy: strict-origin-when-cross-origin" (worth bonus points). **On Apache:** `Header always set Referrer-Policy "strict-origin-when-cross-origin"` Source: W3C Referrer Policy — See also: ANSSI website guide PA-009 v2.0 (2021), §5.4	0 pts
Info	**Cross-Origin-Resource-Policy** Not set (optional; earns bonus points when set). Source: MDN: Cross-Origin-Resource-Policy	0 pts
Info	**Cross-Origin-Opener-Policy** Not set (optional; earns bonus points when set). Source: MDN: Cross-Origin-Opener-Policy	0 pts
Info	**Cross-Origin-Embedder-Policy** Not set (optional; earns bonus points when set). Source: MDN: Cross-Origin-Embedder-Policy	0 pts
Info	**Permissions-Policy** Missing: no restriction on access to browser features (camera, microphone, geolocation). > Add for example "Permissions-Policy: camera=(), microphone=(), geolocation=()". **On Apache:** `Header always set Permissions-Policy "camera=(), microphone=(), geolocation=()"` Source: W3C Permissions Policy	not scored
Info	**security.txt (vulnerability reporting)** No security.txt file: someone who finds a vulnerability on the site does not know whom to warn. > Publish /.well-known/security.txt with at least a Contact and an Expires field (for example generated on securitytxt.org). Source: RFC 9116 (security.txt)	not scored
Compliant	**Subresource Integrity** All scripts are loaded from the site's own domain (Subresource Integrity not needed). Source: W3C Subresource Integrity — See also: ANSSI website guide PA-009 v2.0 (2021), R11, R12	0 pts

Compliant	**X-Content-Type-Options** Present (nosniff). Source: WHATWG Fetch: X-Content-Type-Options — See also: ANSSI website guide PA-009 v2.0 (2021), R6	0 pts
Compliant	**Cross-Origin Resource Sharing (CORS)** Not used: other sites cannot read the home page through CORS. Source: MDN: Cross-Origin Resource Sharing (CORS)	0 pts

Certificate & TLS

To improve	**Accepted TLS versions** The server still accepts old versions (TLS 1.0, TLS 1.1), deprecated since 2021: an attacker who can force an old version weakens the encryption. Accepted: TLS 1.0, TLS 1.1, TLS 1.2, TLS 1.3. > Disable TLS 1.0 and 1.1 and only allow TLS 1.2 and 1.3 (current browsers no longer use the old versions). **On Apache:** `SSLProtocol -all +TLSv1.2 +TLSv1.3` Source: RFC 8996 (deprecating TLS 1.0 and 1.1) — See also: ANSSI TLS guide v1.2 (2020), R3, R4 · ANSSI website guide PA-009 v2.0 (2021), R1 · CNIL personal data security guide (2024): securing websites	-20 pts
To improve	**HTTPS certificate** The certificate expires in 20 days (2026-11-23). > Check that automatic renewal is in place. Source: MDN TLS guide — See also: ANSSI TLS guide v1.2 (2020), R8 · CNIL personal data security guide (2024): securing websites	-10 pts
Compliant	**TLS protocol version** Connection negotiated with TLSv1.3. Source: RFC 8996 (deprecating TLS 1.0 and 1.1) — See also: ANSSI TLS guide v1.2 (2020), R3, R4 · ANSSI website guide PA-009 v2.0 (2021), R1 · CNIL personal data security guide (2024): securing websites	0 pts
Compliant	**Weak cipher suites** No broken cipher suite accepted (RC4, 3DES, export, no encryption or no authentication). Source: RFC 9325 (recommendations for the secure use of TLS)	0 pts
Compliant	**Forward secrecy** Every accepted key exchange has forward secrecy: a stolen private key would not decrypt recorded traffic. Source: RFC 9325 (recommendations for the secure use of TLS)	0 pts
Compliant	**Certificate key** Key strong enough (RSA 2048 bits). Source: RFC 9325 (recommendations for the secure use of TLS)	0 pts

Email protection

To improve	**SPF (authorized senders)** The SPF record ends with "?all" (neutral): it provides almost no protection. > Move to "~all", then "-all" once your senders are listed. **On OVHcloud:** Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation Source: RFC 7208 (SPF) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R44	-20 pts
To improve	**DMARC (anti-spoofing policy)** "none" policy: DMARC monitors but blocks nothing. > After a few weeks of report analysis, move to "quarantine", then "reject". **On OVHcloud:** Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation Source: RFC 7489 (DMARC) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R48+	-20 pts
To improve	**MTA-STS (encrypted email delivery)** Not set: other mail servers may deliver your incoming email without encryption if an attacker tampers with the connection. > Publish an MTA-STS policy (in "testing" mode first), or enable it in your email service. **On OVHcloud:** Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation Source: RFC 8461 (SMTP MTA Strict Transport Security) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), §5.3	-5 pts
Info	**DMARC: reports** No report address (rua): you cannot see who sends email on your behalf. > Add "rua=mailto:..." to receive aggregate reports. **On OVHcloud:** Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation Source: RFC 7489 (DMARC) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R48+	0 pts
Info	**DKIM (email signing)** No DKIM key found among the common selectors tested (42). This is not necessarily a problem: the selector may have another name. > Check in your email service (Google Workspace, Microsoft 365...) that DKIM signing is enabled. Source: RFC 6376 (DKIM) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R46+	not scored
Info	**TLS reporting (TLS-RPT)** Not set: you are not told when other servers fail to deliver your mail securely. > Publish a _smtp._tls TXT record, e.g. "v=TLSRPTv1; rua=mailto:tls-reports@your-domain". **On OVHcloud:** Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation Source: RFC 8460 (SMTP TLS Reporting) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), §5.3	not scored
Info	**DANE (mail server keys in DNS)** Not used. Optional: DANE lets senders check the mail server's key through DNSSEC, and is required by some administrations. > If the domain uses DNSSEC, publish a TLSA record for each mail server (_25._tcp.<server>), or ask your email provider. Source: RFC 7672 (DANE for SMTP) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), §5.3	not scored

Info	**REQUIRETLS** Not announced. Optional and still rare: REQUIRETLS lets a sender require that a message is never passed on without encryption, all along its way. > Enable it if your mail server software supports it (or ask your email provider). Source: RFC 8689 (SMTP REQUIRETLS option) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R42+	not scored
Compliant	**Mail servers (MX)** 2 server(s): mx1.hosting-example.com, mx2.hosting-example.com Source: RFC 7505 (null MX for domains that receive no email)	0 pts
Compliant	**Encryption of incoming email (STARTTLS)** Every mail server reached offers encryption (TLSv1.3). Source: RFC 3207 (STARTTLS for SMTP) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R42	0 pts
Compliant	**Mail server certificates** The certificates of the mail servers are valid. Source: RFC 3207 (STARTTLS for SMTP) — See also: ANSSI Internet gateway guide PA-066 v3.0 (2020), R42	0 pts

Domain & DNS

Critical — **Forgotten subdomains (CT logs)** — -30 pts

4 subdomain(s) found in Certificate Transparency logs (crt.sh), 3 still in use. These subdomains point to a resource that no longer exists at a provider where anyone can create it again, and then publish content on your domain (subdomain takeover): old-shop.bakery-example.com bakery-shop-2019.azurewebsites.net (Azure App Service).

> Delete these DNS records now, or recreate the resource at the provider before someone else does.

Source: RFC 9162 (Certificate Transparency) — See also: ANSSI website guide PA-009 v2.0 (2021), R3

To improve — **DNSSEC** — -15 pts

Not enabled for bakery-example.com: DNS answers are not signed, so a resolver cannot detect forged answers (redirecting visitors or emails to another server).

> Enable DNSSEC at your DNS host, then publish the DS record at your registrar (often a single option in their interface).

On OVHcloud: Web Cloud > Domain names > the domain > Security section > DNSSEC (secure delegation): turn it on. Documentation

Source: RFC 4033 (DNS Security Introduction and Requirements) — See also: ANSSI domain name guide BP-038 v1.3 (2017), R4+ · ANSSI Internet gateway guide PA-066 v3.0 (2020), R50+

To improve — **CAA (allowed certificate authorities)** — -5 pts

No CAA record: any certificate authority may issue a certificate for this domain.

> Publish a CAA record naming the authority you use, e.g. 0 issue "letsencrypt.org".

On OVHcloud: Web Cloud > Domain names > the domain > DNS zone tab, then add or edit the record. Documentation

Source: RFC 8659 (DNS Certification Authority Authorization)

To improve — **Transfer lock** — -5 pts

The domain is not locked against transfers: with a stolen access to your registrar account, it is easier to move it elsewhere.

> Turn on the transfer lock (often called "registrar lock") at your registrar.

Source: RFC 5731 (domain status, including transfer prohibited) — See also: ANSSI domain name guide BP-038 v1.3 (2017), R1, R3+

Compliant — **Domain expiry date** — 0 pts

The domain bakery-example.com is registered until 2027-05-21 (199 days). Registrar: Example Registrar.

Source: RFC 9083 (RDAP, registration data of domain names) — See also: ANSSI domain name guide BP-038 v1.3 (2017), §4.10

Method. Passive audit carried out by Loïc Tellier using public information only: DNS records, the certificate presented by the server and the home page. No intrusion testing was performed. Grades. The website grade follows the Mozilla HTTP Observatory scoring (penalties and bonuses per header). The certificate, email and DNS grades use this project's own scale, based on the standards cited under each item. The overall grade is the lowest of the four. Limits. This audit does not cover the site's applications, workstations or user accounts. It gives an overview of the exposure visible from the Internet on the date shown. The ANSSI recommendations cited show what each check relates to; meeting them fully also depends on settings that cannot be seen from outside, so this report is not a certificate of compliance.